Day 6: Vulnerability Analysis (Finding the Cracks)

Table of Contents

1. Introduction
2. Objective of the Day
3. What is Vulnerability Analysis?
4. Manual vs. Automated Analysis
5. The Nmap Scripting Engine (NSE)
6. What I Did Today
7. What I Learned (Key Outcomes)
8. Hands-on Examples: Identifying Vulnerabilities

1. Introduction

Reconnaissance told us which doors are open (Ports) and who is standing behind them (Services). Today, we move to the next logical step: **Vulnerability Analysis**. This is the process of checking those services against databases of known bugs, misconfigurations, and weaknesses to see if there is a way to gain unauthorized access.

2. Objective of the Day

The goal of Day 6 is to bridge the gap between "Scanning" and "Exploitation." I focused on taking the version numbers discovered in Day 5 and researching if they are "vulnerable." I also explored how to use automated scripts to find common security flaws.

3. What is Vulnerability Analysis?

Vulnerability analysis is the systematic review of security weaknesses in an information system. In our lab, we are looking for:

- **Unpatched Software:** Services like `vsftpd 2.3.4` that have famous "backdoors."
- **Default Credentials:** Systems that still use `admin/admin` or `root/root`.
- **Misconfigurations:** Services that allow anonymous login when they shouldn't.

4. Manual vs. Automated Analysis

- **Manual Research:** Using the service name and version number (e.g., *Apache 2.2.8*) and searching it on **Exploit-DB** or **Google**.
- **Automated Scanning:** Using tools that automatically check for thousands of vulnerabilities at once.

5. The Nmap Scripting Engine (NSE)

Nmap is not just a scanner; it's a vulnerability hunter. The **NSE** allows us to run scripts that check for specific vulnerabilities.

- **Auth scripts:** Check for default passwords.
- **Vuln scripts:** Check for specific known exploits.
- **Default scripts (-sC):** Runs a set of safe, common scripts.

6. What I Did Today

1. **Vulnerability Research:** I took the service list from my Day 5 Nmap scan and used the `searchsploit` command in Kali to see if any exploits exist for those versions.
2. **Running Vuln Scripts:** I ran an Nmap vulnerability scan using the command:

```
nmap --script vuln [Victim-IP]
```

1. **Analyzing Results:** I identified that the FTP service on Metasploitable2 is highly vulnerable to a specific "Backdoor" attack.
2. **Documentation:** I mapped each open port to a potential risk, creating a "Vulnerability Map" of my victim machine.

7. What I Learned

- **Versions Matter:** I learned that even a small change in a version number (like 2.3.4 vs 2.3.5) can be the difference between a secure system and a completely hacked one.
- **False Positives:** Sometimes automated tools say a system is vulnerable when it isn't. I learned to verify my findings with manual research.
- **CVEs:** I learned about **Common Vulnerabilities and Exposures (CVE)**—the unique ID numbers given to every major security bug in the world.

Key Takeaway for Newbies:

"Don't just scan; analyze. A scanner tells you a window is open; analysis tells you if the lock is broken."

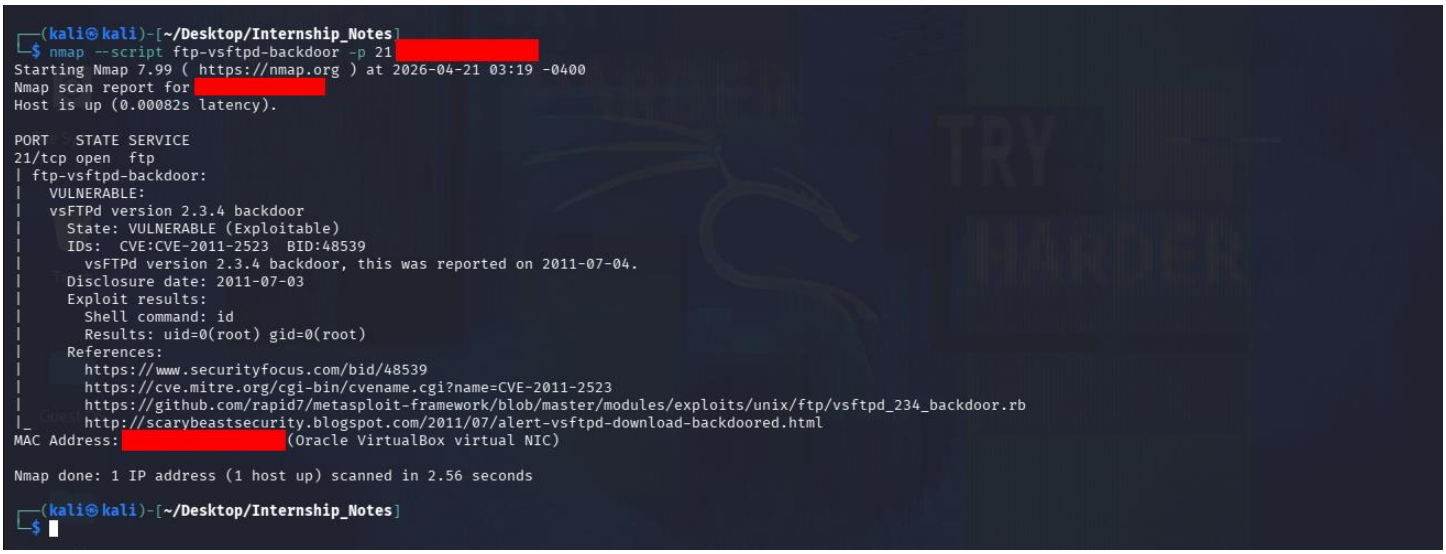
8. Hands-on Examples: Identifying Vulnerabilities

- **Task:** Use Nmap scripts to find a vulnerability on the Metasploitable2 machine.

Execution:

1. Run: `nmap --script ftp-vsftpd-backdoor -p 21 [Victim-IP]`
2. Observe the output. If it says "VULNERABLE," you have found a way in!
3. Use `searchsploit vsftpd` to see the details of the exploit.

Screenshot 1: Terminal showing the results of `nmap --script vuln`.

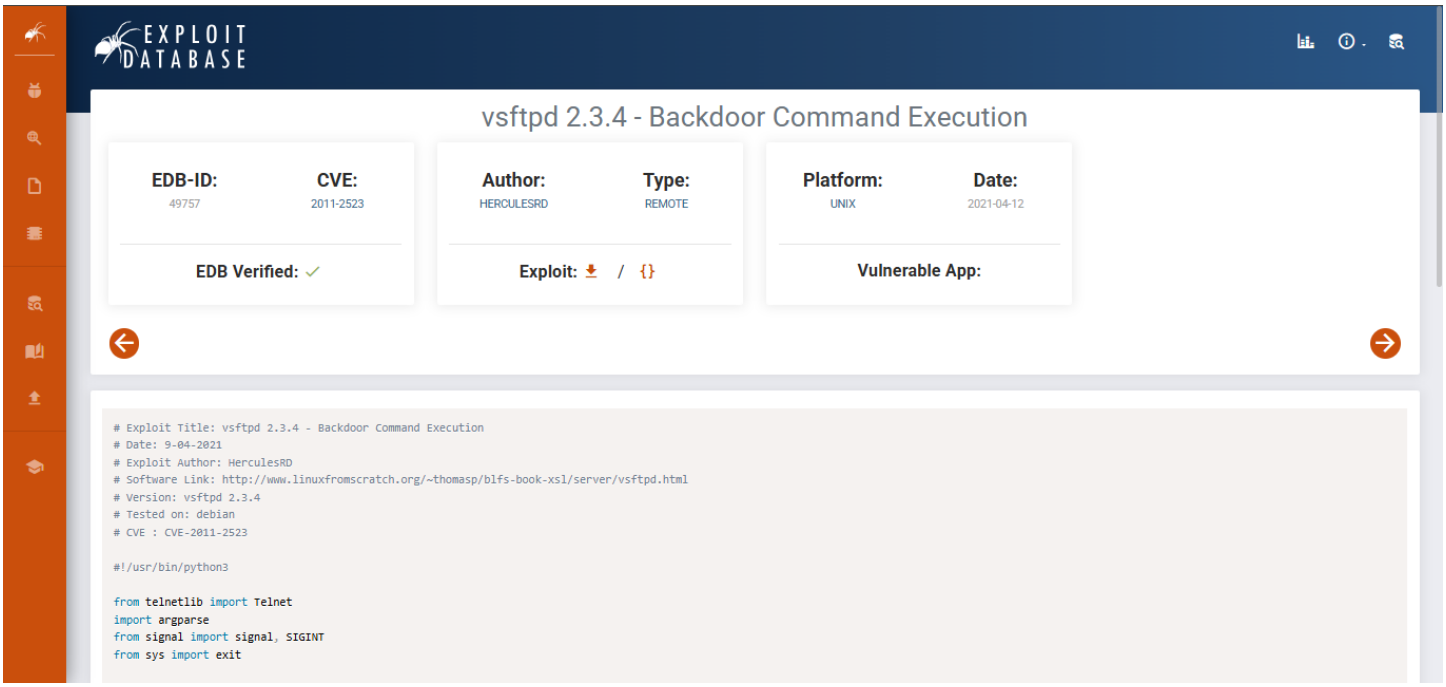


```
┌──(kali㉿kali)-[~/Desktop/Internship_Notes]
└─$ nmap --script ftp-vsftpd-backdoor -p 21[redacted]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 03:19 -0400
Nmap scan report for [redacted]
Host is up (0.00082s latency).

PORT   STATE SERVICE
21/tcp open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://www.securityfocus.com/bid/48539
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|_      http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
MAC Address: [redacted](Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.56 seconds

┌──(kali㉿kali)-[~/Desktop/Internship_Notes]
└─$
```

Screenshot 2: The output of the `searchsploit` command showing a list of exploits.

```
┌──(kali㉿kali)-[~/Desktop/Internship_Notes]
└─$ searchsploit vsftpd
---------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                |  Path
---------------------------------------------------------------------------------------------- ---------------------------------
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote Memory Consumption                                | linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1)                                | windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2)                                | windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service                                                              | linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution                                                     | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                                        | unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service                                                       | multiple/remote/49719.py
---------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results

┌──(kali㉿kali)-[~/Desktop/Internship_Notes]
└─$ searchsploit vsftpd 2.3.4
---------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                |  Path
---------------------------------------------------------------------------------------------- ---------------------------------
vsftpd 2.3.4 - Backdoor Command Execution                                                     | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                                        | unix/remote/17491.rb
---------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

Screenshot 3: A screenshot of **Exploit-DB** or a CVE website showing details of a vulnerability you found.



Date: Sunday, April 12, 2026 **Daniyal Shahid**